

ПРОБЛЕМЫ ИСПОЛЬЗОВАНИЯ ИСКУССТВЕННОГО ИНТЕЛЛЕКТА В АУДИТЕ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

Лукьянов Р.В.

Финансовый университет при Правительстве Российской Федерации, Москва, Россия
E-mail: 212914@edu.fa.ru

Научный руководитель: Резниченко С.А., к.т.н., доцент

Финансовый университет при Правительстве Российской Федерации, Москва, Россия
E-mail: RSA_5@mail.ru

Аннотация. В наше время, когда для защиты от быстро развивающихся угроз безопасности информации также быстро стараются развиваться и системы защиты информации, проводить их аудит традиционными методами становится все сложнее, поскольку обычный человек может и не заметить небольшие аномалии и недочеты в системе. На помощь ему в этом вопросе приходит искусственный интеллект, а в частности нейросети и машинное обучение, которые призваны помочь аудиторам в их деятельности. Грамотное использование методов искусственного интеллекта позволяет упростить как рутинную работу, так и тяжелую ношу анализа больших данных в самых массивных и запутанных системах защиты информации. Целью этой работы является анализ всех стадий проведения аудита информационной безопасности от составления программы аудита до составления отчета по нему на возможность внедрения в них технологий искусственного интеллекта и машинного обучения, а также описание возможных проблем, которые могут возникнуть при попытке внедрения этих инновационных технологий. В статье описано на каких этапах проведения аудита информационной безопасности внедрение технологий искусственного интеллекта и машинного обучения являются наиболее уместным и полезным, а на каких этапах можно столкнуться с проблемами при внедрении этих технологий, а также указаны возможные причины возникновения этих проблем и пути их решения, если это возможно. Выводы, сделанные в этой статье, могут быть полезны как для многих аудиторских компаний, занимающихся внешним аудитом, так и для обычных организаций, желающих провести внутренний аудит своей информационной системы с использованием инновационных технологий искусственного интеллекта.

Ключевые слова: информационная безопасность, аудит, искусственный интеллект, машинное обучение, защита информации, менеджмент аудита.

PROBLEMS OF USING ARTIFICIAL INTELLIGENCE IN INFORMATION SECURITY AUDITING

R. V. Lukyanov

Financial University under the Government of the Russian Federation, Moscow, Russia
E-mail: 212914@edu.fa.ru

Scientific supervisor: S.A. Reznichenko, Ph.D., Associate Professor

Financial University under the Government of the Russian Federation, Moscow, Russia
E-mail: RSA_5@mail.ru

Abstract. Nowadays, when information security systems are also rapidly developing to protect against rapidly evolving threats to information security, it is becoming increasingly difficult to audit them using traditional methods, because an ordinary person may not notice small anomalies and flaws in the system. Artificial intelligence, in particular neural networks and machine learning, which are designed to help auditors in their activities, comes to his aid in this matter. The competent use of artificial intelligence methods can simplify both routine work and the heavy burden of analyzing big data in the most massive and confusing information protection systems. The purpose of this paper is to analyze all stages of information security audit from the audit program to the audit report on the possibility of introducing artificial intelligence and machine learning technologies into them, as well as to describe possible problems that may arise when trying to implement these innovative technologies. The article describes at what stages of the information security audit the introduction of artificial intelligence and machine learning technologies is most appropriate and useful, and at what stages it is possible to encounter problems with the introduction of these technologies, as well as the possible causes of these problems and ways to solve them, if possible. The findings in this paper can be useful for many external audit firms as well as for ordinary organizations wishing to conduct an internal audit of their information system using innovative artificial intelligence technologies.

Keywords: information security, audit, artificial intelligence, machine learning, information protection, audit management.

ВВЕДЕНИЕ

Сейчас мы всё чаще слышим о том, что технология искусственного интеллекта становится всё популярнее. Крупные международные корпорации стараются внедрять эту технологию куда только можно. Например, компания *Microsoft* сделала своего чат-бота *Copilot*, использующего технологии нейросетей и работающего на базе *GPT-4*, полноценной функцией операционной системы *Windows 11* [8]. Этот пример показывает, что искусственный интеллект уже стал полноценной частью нашей повседневной жизни. Теперь настало время понять, насколько эта технология может быть полезна для аудиторов информационной безопасности.

Искусственный интеллект уже сейчас используется при проведении бухгалтерского аудита организаций. Возможности машинного обучения и анализа больших данных помогают

находить аномалии в отчетности и определять манипуляции с балансом, не говоря о том, что с помощью технологий обработки естественного языка возможно автоматизировать многие рутинные задачи аудиторской группы, включая анализ документации проверяемой организации и составление отчётов по аудиту [9].

Но не все аудиторские группы готовы использовать технологию искусственного интеллекта в своей деятельности. Технологическая целевая группа Совета по стандартам аудита AICPA провела опрос, в котором различным аудиторским группам, работающим по бухгалтерскому аудиту, было предложено назвать причины, по которым они отказываются использовать искусственный интеллект при проведении аудита. Результаты этого опроса приведены в табл. 1.

Табл. 1 - Основные причины, по которым аудиторские группы не применяют технологию ИИ. Источник: [10]

Причина	Процент респондентов
Отсутствие профессиональной подготовки и инфраструктуры	23%
Технология слишком дорогая	17%
Технология бесполезна	17%
Невозможность получения доступа к важной информации	13%
Технология сложна в использовании	12%
Плохой контроль целостности данных	4%
Опасения по поводу того, что другие подвергнут сомнению правильность использования технологии	4%
Опасения по поводу нарушения конфиденциальности данных при обработке	4%
Отсутствие стандартов по использованию технологии	3%
Выходные данные тяжело использовать в дальнейшем	2%
Недостаток знаний о технологии	1%

Из результатов этого опроса видно, что больше половины всех респондентов не используют технологию искусственного интеллекта для проведения бухгалтерского аудита либо из-за того, что не умеют её правильно применять или считают её попросту ненужной, либо по причине того, что считают применение этой технологии слишком дорогим и ресурсоёмким в рамках проведения одного аудита.

Данная работа написана в том числе с целью показать, что технологию искусственного интеллекта можно и нужно применять при проведении аудита. Но при этом необходимо

определить правила и разумные пределы его использования и самые полезные задачи для искусственного интеллекта и машинного обучения, для того чтобы сильно упростить работу аудиторской группе. Само применение этой технологии будет рассмотрено на примере аудита информационной безопасности, поскольку актуальность использования искусственного интеллекта для защиты информации растет с каждым годом, благодаря огромным возможностям, которые может дать умелое применение этой инновационной технологии.

ИСКУССТВЕННЫЙ ИНТЕЛЛЕКТ И АУДИТ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

Перед тем, как перейти к рассмотрению лучших практик применения технологии искусственного интеллекта в аудите информационной безопасности, необходимо

разобраться из чего он состоит. Порядок проведения аудита информационной безопасности описан в стандарте ГОСТ Р ИСО/МЭК 27007-2014 [2]. Схематично этапы проведения аудита изображены на рис. 1.

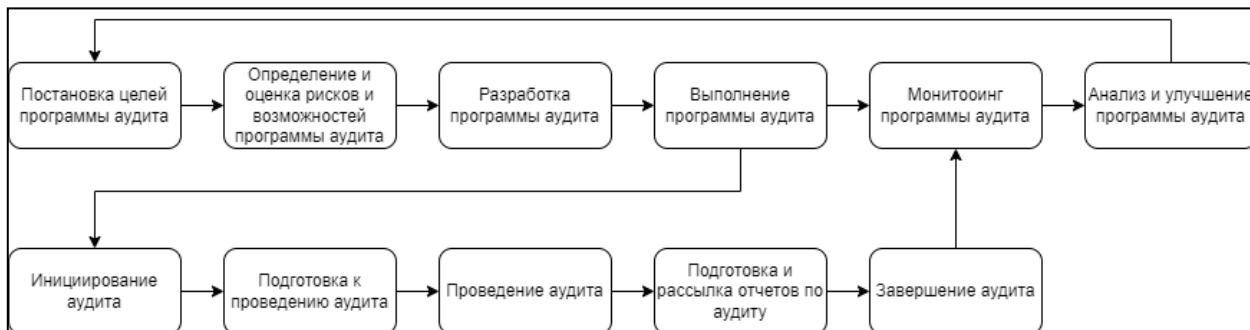


Рис. 1 - Этапы проведения аудита информационной безопасности. Источник: [3]

Эта схема состоит из двух частей: менеджмент программы аудита и, непосредственно, само проведение аудита. Стоит отметить, что в этой схеме методика проведения аудита информационной безопасности рассмотрено через призму цикла Деминга: все этапы можно чётко сгруппировать в элементы цикла PDCA [4]. Так к этапу планирования в случае менеджмента программы аудита будут относиться: постановка целей программы, оценка рисков и возможностей и сама разработка программы, а в случае проведения аудита к этапу планирования относятся инициирование аудита и подготовка к проведению аудита. Следом за этапом планирования идёт этап исполнения, в менеджменте программы аудита информационной безопасности ему соответствует этап выполнения программы аудита, а в случае проведения самого аудита - этапы проведения аудита и создания отчёта по аудиту. Следующим этапом по циклу Деминга является проверка. Он соответствует этапу мониторинга программы аудита и завершения аудита. Последним этапом в модели PDCA идёт принятие необходимых мер. На этом этапе в случае менеджмента программы аудита выполняется анализ и улучшение программы аудита, а в случае самого аудита информационной безопасности могут выполняться необходимые действия по его результатам, если удалось выявить какие-либо проблемы в системе.

Также перед внедрением искусственного интеллекта в аудит необходимо разобраться, не нарушает ли его использование принципы аудита информационной безопасности, перечисленные в стандарте:

1) Честность - основа профессионализма;

В честности искусственному интеллекту нет равных среди людей, он не станет врать, если его правильно обучили. Поэтому можно заявить, что при использовании искусственного интеллекта в аудите информационной безопасности этот принцип будет соблюдаться.

2) Беспристрастное представление отчётов;

В этом тоже можно успешно положиться на искусственный интеллект. Отчёты, созданные ИИ лишены какой-либо субъективности в вопросах безопасности.

3) Профессиональная осмотрительность и обдуманность решений;

Искусственный интеллект способен принимать решения довольно быстро, но так как у ИИ отсутствует процесс мышления, как у человека, к нужному и самому полезному выводу, на который он способен, ИИ приходит сразу же. Ему не нужно дополнительное время, чтобы подольше обдумать принятое решение. Значит в этом вопросе искусственный интеллект не подведёт команду аудиторов.

4) Конфиденциальность;

Здесь от искусственного интеллекта почти ничего не зависит. Конфиденциальность

выходных данных, полученных после работы ИИ, должна обеспечиваться аудиторской группой, ровно также, как и входные данные для анализа, если они содержат важную для проверяемой организации информацию.

5) Независимость и беспристрастность при проведении аудита;

Искусственному интеллекту, в отличие от человека, не свойственны личные чувства и деструктивные мотивы. Также у ИИ не может случиться конфликт интересов с проверяемой организацией, поэтому при использовании искусственного интеллекта в аудите информационной безопасности этот принцип его проведения тоже нарушен не будет.

Теперь перейдём к рассмотрению возможностей внедрения технологии искусственного интеллекта как на этапах менеджмента программы аудита, так и на этапах проведения самого аудита информационной безопасности. Сам процесс рассмотрения будет поделён на 4 части в соответствии с циклом Деминга.

Этап планирования

Во время постановки целей программы аудита формулируются входные данные для всего аудита. Этими данными могут являться: требования к безопасности, поставленные организацией, требования стандартов, в частности ГОСТ Р ИСО/МЭК 27001-2021 [1], а также уже известные риски информационной безопасности организации. Все эти цели могут быть успешно использованы для предоставления контекста искусственному интеллекту в целях помощи аудиторам. Такая технология ИИ, как *NLP* (обработка естественного языка), позволяет успешно анализировать документы организации в гораздо меньшее время, чем их ручная вычитка [5]. Стоит отметить, что, если организация ведёт постоянный мониторинг рисков информационной безопасности, сам процесс сбора информации также можно автоматизировать для упрощения деятельности аудиторской команды. Здесь налицо первая проблема, заключающаяся в достоверности информации, получаемой для постановки целей программы аудита, а также для последующего их вынесения в контекст работы искусственного

интеллекта. Если полученные данные неверны, то весь анализ, проведённый ИИ, приведёт к ложным выводам, что может значительно затруднить последующую деятельность аудиторской группы.

Далее в рамках менеджмента программы аудита на этом этапе определяются и оцениваются риски и возможности для программы аудита. Здесь искусственный интеллект способен выполнять достаточно большое количество функций. Технологии машинного обучения позволяют анализировать не какую-то часть данных, а весь массив. Помимо уменьшения времени, требуемого на анализ, эта возможность также сильно упростит жизнь аудиторам, заменив их ручной труд. Также ИИ способен к агрегации данных из этих массивов, что позволяет структурировать важные данные из разных источников для их последующего использования в оценке рисков и выявления закономерностей [11]. Главная проблема при всём этом может заключаться помимо недостоверной информации в том, что организация может отказаться предоставлять полную версию массива данных для их обработки, опасаясь за утрату конфиденциальности содержащейся в ней важной для организации информации. Этот вопрос может быть решён с помощью контактов между аудиторской группой и организацией по части вопросов об использовании дополнительной информации для обеспечения объективности результатов аудита, а также заключение дополнительных договоров между сторонами.

Последним, что предпринимается на этом этапе в рамках менеджмента программы аудита, является разработка программы аудита. Здесь и будут реализованы все те входные данные, собранные во время постановки целей и анализа рисков и возможностей. На этом этапе аудиторская группа получает аналитический отчёт от искусственного интеллекта с ролями и зонами ответственности аудиторов, возможная оценка их компетентности, а также отчёт по объёму всего аудита и распределению необходимых ресурсов для его проведения. Стоит заметить, что составление такого отчёта с помощью технологий ИИ существенно снижает вероятность ошибки,

благодаря отсутствию человеческого фактора при анализе всех данных [12].

Что касается инициирования аудита, то оно делится на 2 этапа: установление контакта с проверяемой организацией и определение возможности проведения аудита. Если в первом этапе искусственный интеллект мало чем поможет, ведь при установлении контакта аудиторская компания и проверяемая организация договариваются о различных условиях, в которых будет проводиться аудит, а также запрашивается доступ к информации для её последующего использования при аудите, то в рамках определения возможностей проведения аудита ИИ может использоваться в качестве оценщика этих возможностей при всех входящих данных, таких как оценка достаточности ресурсов или информации для проведения аудита.

Также на этом этапе осуществляется подготовка к проведению аудита. Здесь тоже очень помогут перечисленные выше возможности искусственного интеллекта по части анализа больших массивов данных, а именно большого объёма документации организации, нуждающейся в детальном рассмотрении. Ещё на этом этапе ИИ можно использовать для упрощения распределения работы среди членов аудиторской группы на основе их профессиональных навыков, компетенций, полномочий и рабочих предпочтений. Но стоит учесть, что мнение членов аудиторской группы может расходиться с результатами аналитической работы искусственного интеллекта, поэтому этот вопрос желательно закреплять нормативно. Искусственный интеллект на этом этапе также может быть полезен для подготовки документированной информации для аудита с помощью ранее описанной технологии *NLP* [13].

Этап исполнения

На этом этапе происходит непосредственное проведение самого аудита информационной безопасности, а также рассылка отчёта по его результатам. Искусственный интеллект здесь начинает играть одну из важнейших ролей во всём аудиторском цикле. Он распределяет роли и обязанности между как участниками аудиторской группы, так и наблюдателями от организации в

зависимости от факторов, перечисленных в предыдущем абзаце. Также на вступительном заседании с помощью ИИ и нейросетей, в частности, аудиторская группа может представить тезисную выжимку из объёмной программы аудита информационной безопасности для упрощения взаимодействия с представителями проверяемой организации.

Далее, в зависимости от конечной цели аудита, искусственный интеллект может выполнять самые разные задачи. Всё начинается со сбора всей необходимой информации, включая внутренние документы организации, связанные с информационной безопасностью, информации обо всех автоматизированных системах, технических средств защиты информации, планах помещений, технических каналов утечки информации, персональных ЭВМ сотрудников, внутренней сети организации и другой необходимой для аудита информации [6]. Вся эта информация является входными данными для последующей их обработки при помощи машинного обучения, заносить её туда могут либо вручную аудиторы, либо она может поступать в автоматическом режиме, например при использовании сканера уязвимостей или при помощи инструментов для тестирования на проникновение, что также может помочь при проведении внутреннего аудита [7]. Входными данными также должны являться нормативные требования к безопасности, описанные в стандартах ГОСТ Р ИСО/МЭК 27001-2021 и ГОСТ Р ИСО/МЭК 27006-2020.

Следующим шагом является обработка всей входящей информации искусственным интеллектом. Анализ данных происходит в соответствии с целью аудита. Если речь идёт об аттестации объектов информатизации, то должно проверяться соответствие уровня защищенности систем информационной безопасности тем, которые прописаны в нормативных документах и стандартах. Если целью аудита является контроль защищённости информации ограниченного доступа, то в этом случае искусственный интеллект проводит анализ возможных каналов утечки этой информации, а также проверяет эффективность средств защиты информации,

развёрнутых на объекте. Искусственный интеллект также может помочь в проектировании защищённых систем. Ориентируясь на нормативные требования, ИИ в состоянии разработать концепцию информационной безопасности, а также он способен давать персонализированные советы по внедрению систем защиты информации и проектированию безопасных помещений и средств передачи информации. Здесь стоит сделать очень важную оговорку: помимо достоверных входных данных сама модель машинного обучения должна быть правильно обучена. Если модель не обучена под конкретные цели, либо обучена неправильно, то это приведёт к неверным результатам работы всей внедрённой системы искусственного интеллекта.

После проведения аудита по нему формируется отчёт. В формировании отчёта помощь ИИ будет аудиторам как нельзя кстати. Если почти весь процесс проведения аудита ИБ был выполнен искусственным интеллектом, то этот отчёт может формироваться в автоматическом режиме без участия самих аудиторов. Но несмотря на это, процесс создания отчёта, как и процесс проведения аудита ИИ должен контролироваться аудиторской группой для предупреждения возможных проблем. В случае если была автоматизирована только часть аудита, входными данными для отчёта могут являться заключения группы аудиторов, по которым ИИ будет формировать отчёт по аудиту и в автоматическом режиме отправлять его всем заинтересованным сторонам.

Этап проверки

Этот этап начинается с завершения аудита. Аудит считается завершённым, если выполнены все запланированные мероприятия, либо достигнуто иное соглашение с заказчиком [3]. После завершения аудита вся информация, полученная в результате аудита, уничтожается или продолжает храниться в зависимости от договорённости с проверяемой организацией. Поэтому мониторинг программы аудита

осуществляется исключительно на основании оценки её эффективности. Эту оценку также способен давать искусственный интеллект на основе следующих данных: результативность членов аудиторской группы, степень выполнения плана аудита, выполнены ли все поставленные цели, а также оценки документированной информации аудита.

После определения оценки искусственный интеллект может предложить возможные пути изменения программы аудита для последующих аудитов, если это будет необходимо. В этой ситуации возможны те же самые этические проблемы – некоторые могут не согласиться с вынесенным ИИ вердиктом и требовать экспертной оценки проделанной работы.

Этап принятия необходимых мер

Если искусственный интеллект или экспертная оценка всё-таки выявили возможные пути улучшения программы аудита, то перед проведением всех последующих аудитов информационной безопасности эта программа должна быть улучшена. Этапы проверки и принятия необходимых мер могут проходить на всех этапах проведения аудита информационной безопасности, особенно если речь идёт о внутреннем аудите, в котором активно используются автоматические системы мониторинга уровня защиты информации в организации.

ЗАКЛЮЧЕНИЕ

Пришло время подвести итоги. При подробном рассмотрении стадий проведения аудита выяснилось, что почти на всех из них может пригодиться использование искусственного интеллекта. В каких-то ситуациях он может помочь автоматизировать рутинную работу аудиторов, а в каких-то дать экспертную оценку эффективности проведения аудита. Но в процессе рассмотрения возможностей ИИ также был выявлен ряд проблем, который может мешать полноценному внедрению искусственного интеллекта в аудит (рис. 2).



Рис. 2 - Основные проблемы при внедрении ИИ в аудит информационной безопасности. Источник: составлено автором

Несмотря на то, что проблем немало, самой важной, на мой взгляд, является проблема отсутствия стандартов и нормативных актов, регламентирующих использование искусственного интеллекта в аудите. Подобные стандарты уже существуют в различных сферах, таких как клиническая медицина или транспорт, но по применению ИИ в аудите информационной безопасности государственного стандарта пока ещё не существует [14].

Но даже несмотря на наличие всех этих проблем, искусственный интеллект всё ещё способен очень сильно упростить и автоматизировать весь процесс проведения аудита информационной безопасности. Регулярное проведение аудита в организации как внутреннего, так и внешнего, способствует обеспечению постоянной защищённости её бизнес-процессов, а значит и полноценного функционирования [15]. А для упрощения и увеличения эффективности аудита организации должны работать в сторону обеспечения интеграции систем на базе ИИ в свою информационную систему, а также заниматься обучением своих сотрудников для работы с этими системами. Использование средств мониторинга на базе искусственного интеллекта способно

почти полностью исключить необходимость регулярного проведения внутреннего аудита в организации. А аудиторские компании, в свою очередь, также должны заниматься повышением квалификации своих сотрудников для работы с ИИ и внедрять эту технологию в свои методы проведения аудита.

СПИСОК ИСПОЛЬЗУЕМЫХ ИСТОЧНИКОВ

- [1] ГОСТ Р ИСО/МЭК 27001-2021 «Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования»
- [2] ГОСТ Р ИСО/МЭК 27007-2014 «Информационная технология. Методы и средства обеспечения безопасности. Руководства по аудиту систем менеджмента информационной безопасности»
- [3] ГОСТ Р ИСО 19011-2021 «Оценка соответствия. Руководящие указания по проведению аудита систем менеджмента»
- [4] *Ретин В.В., Елиферов В.Г.* Процессный подход к управлению. Моделирование бизнес-процессов. — М.: РИА «Стандарты и качество», 2008. — 408 с.
- [5] *Shervin Minaee, Nal Kalchbrenner, Erik Cambria, Narjes Nikzad, Meysam Chenaghlu.* Deep Learning Based Text Classification: A Comprehensive Review // arXiv:2004.03705 [cs, stat]. — 2020-04-05.

- [6] *Ярочкин В.И.* Информационная безопасность: Учебник для студентов — М.: Академический Проект; Гаудеамус, 2-е изд., — 2004. — 544 с.
- [7] *Долгин А.А., Хорев П.Б.* Разработка сканера уязвимостей компьютерных систем на основе защищенных версий ОС Windows. Труды международной научно-технической конференции. — М.: «Информационные средства и технологии», 2005. — Т. 2.
- [8] *Alan Meeus.* Copilot coming to Windows 10. - URL: <https://techcommunity.microsoft.com/t5/windows-it-pro-blog/> (дата обращения: 20.03.24).
- [9] *Brett Johnson.* How AI Is Helping in Audit Automation/ - URL: <https://www.highradius.com/resources/Blog/leveraging-ai-in-accounting-audit/> (дата обращения: 18.03.24).
- [10] AICPA Auditing Standards Board Technology Task Force. - URL: <https://www.aicpa-cima.com/resources/landing/asb-auditing-standards-board> (дата обращения: 19.03.24).
- [11] *Adeline Chan.* Can AI Be Used for Risk Assessments? - URL: <https://www.isaca.org/resources/news-and-trends/industry-news/2023> (дата обращения: 22.03.24).
- [12] The Role of Artificial Intelligence in Auditing: Enhancing Accuracy and Efficiency. - URL: <https://www.rsm.global/uae/insights/> (дата обращения: 22.03.24).
- [13] *Shini Menon.* How Can AI Drive Audits? - URL: <https://www.isaca.org/resources/isaca-journal/issues/2021/volume-4/how-can-ai-drive-audits> (дата обращения: 23.03.24).
- [14] Стандарты по направлению «Искусственный интеллект». - URL: <https://www.rst.gov.ru/portal/gost/home/standarts/aistandarts> (дата обращения: 24.03.24).
- [15] *Лукьянов Р.В.* Управление финансами как бизнес-процесс и способы обеспечения его непрерывности// Вестник науки. 2023. №5 (62). — с. 43-47